

Cryptography



Cryptography

- Types of Cryptography
- Evolution of Encryption Algorithms
- Salt
- Nonce
- Digital Certificates
- Digital Signatures
- Attacks on Crypto

Labs

- Practicing cryptography with Cyberchef
- Scan a website with the help of a website scanner from Qualys and submit your analysis report on the same

What is Cryptography?

- Cryptography is the science and art of protecting information by *converting readable data (plaintext) into unreadable form (ciphertext)* so that only authorized parties can access it.
- Cryptography is a technique used to secure data and communications using codes, ciphers and algorithms.

Cryptography



Why is Cryptography important?

It ensures the core security goals of information:

- ✓ **Confidentiality** – Keeps data private
- ✓ **Integrity** – Detects data tampering
- ✓ **Authentication** – Verifies user identity
- ✓ **Non-repudiation** – Sender can't deny sending

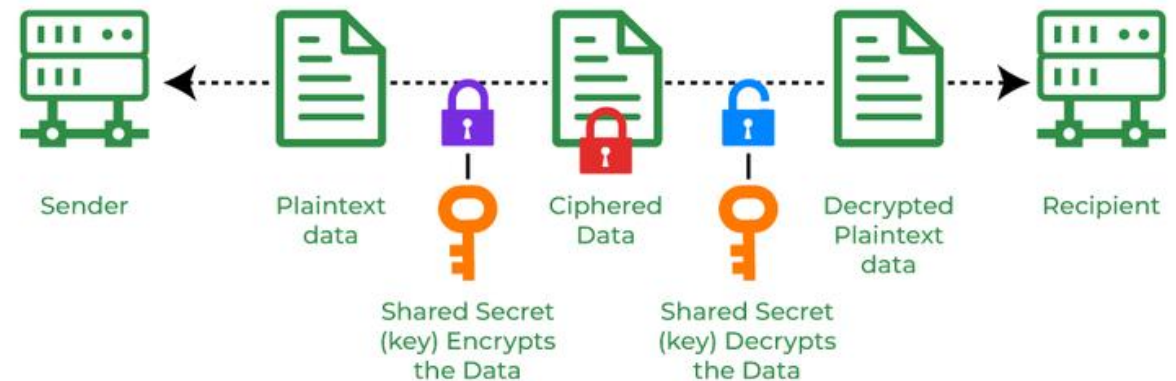
These directly support the CIA Triad.

Types of Cryptography



Types of Cryptography - Symmetric Key

- Symmetric Key Cryptography is an encryption system where the sender and receiver of a message use a **single common key** to encrypt and decrypt messages.
- Same key is used to encrypt and decrypt and used with disk encryption & VPN tunnel.
- Symmetric Key cryptography is faster and simpler but the problem is that the sender and receiver have to somehow exchange keys securely.
- The most popular symmetric key cryptography systems are
 - Data Encryption Systems (DES) and
 - Advanced Encryption Systems (AES)
 - 3DES



Types of Cryptography - Asymmetric Key

- In Asymmetric Key Cryptography a pair of keys is used to encrypt and decrypt information.
- It uses 2 keys
 - Public Key (share with others)
 - Private key (Kept secret)
- A sender's public key is used for encryption and a receiver's private key is used for decryption.
- Used in HTTPS, Digital Signatures and Email Encryption.
- Public keys and Private keys are different. Even if the public key is known by everyone the intended receiver can only decode it because he holds his private key.
- The most popular asymmetric key cryptography algorithm is the **RSA algorithm**.



Types of Cryptography - Hash Functions

- Hash functions do not require a key.
- Instead, they use mathematical algorithms to convert messages of any arbitrary length into a fixed-length output, known as a hash value or digest.
- Hash functions are designed to be one-way, meaning the original input cannot be derived from the output (Cannot be reversed.).

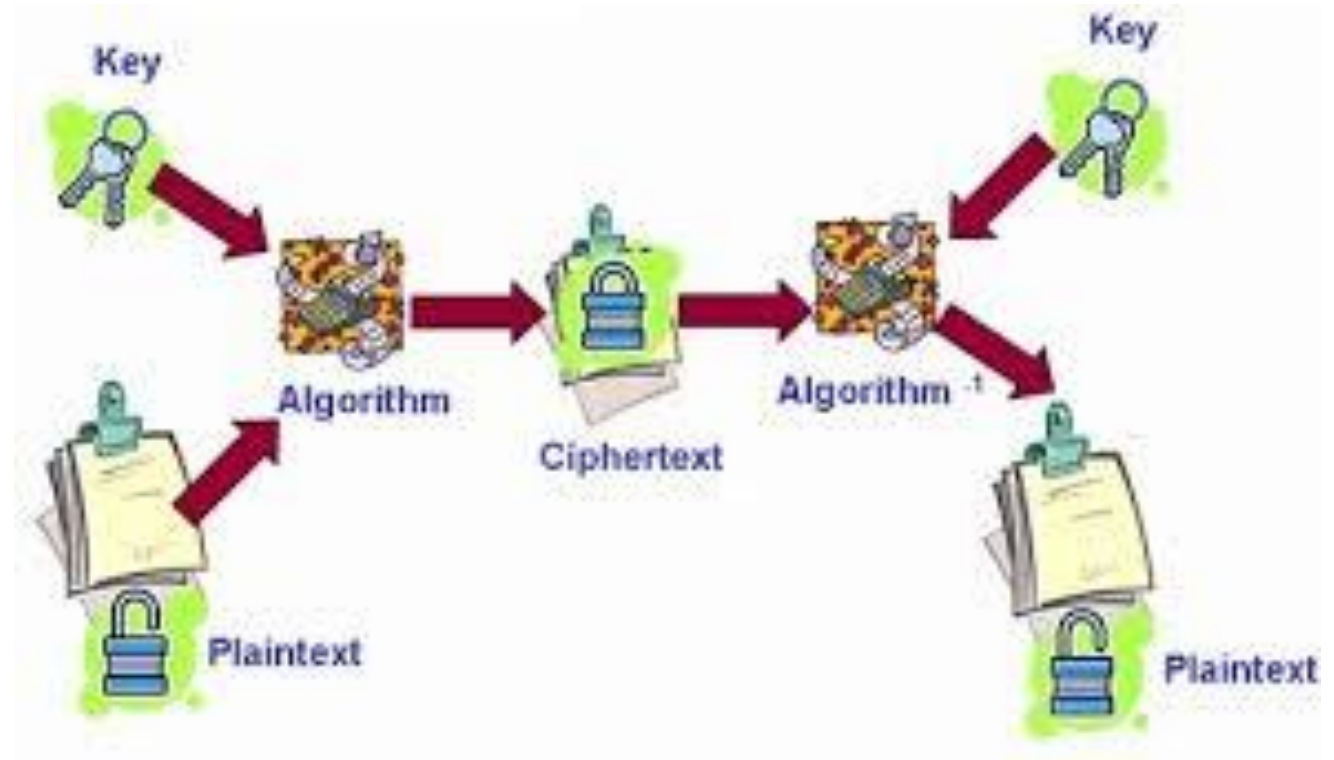
- Example:

- SHA-1 (Secure Hash Algorithm)
- SHA-256
- MD5
- MD6

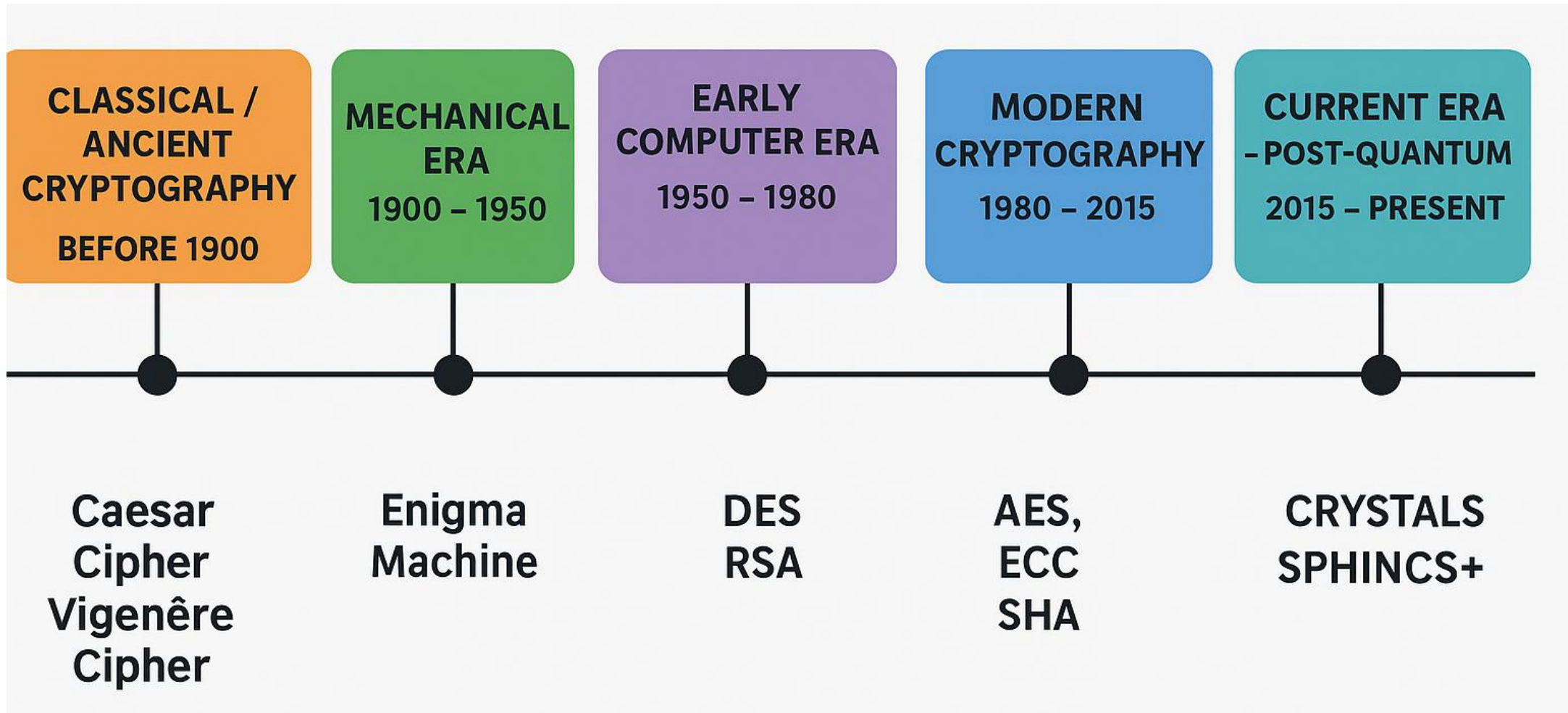


Where is Cryptography used?

- HTTPS (secure websites)
- ATM and online banking
- WhatsApp/Signal encryption
- Password protection
- Blockchain & cryptocurrencies
- Digital certificates



Evolution of Encryption Algorithms



Classical / Ancient Cryptography

These were manual ciphers used mainly in warfare and secret messages

- **Caesar Cipher (100 BC)**

- Shifted each letter by a fixed number.
- Weakness: Easy to break with frequency analysis.

- **Substitution Cipher**

- Each letter replaced with another.
- Still based on patterns → breakable.

- **Vigenère Cipher (1500s)**

- Used a word as a key for multiple shifts.
- Strong for its time but eventually broken.

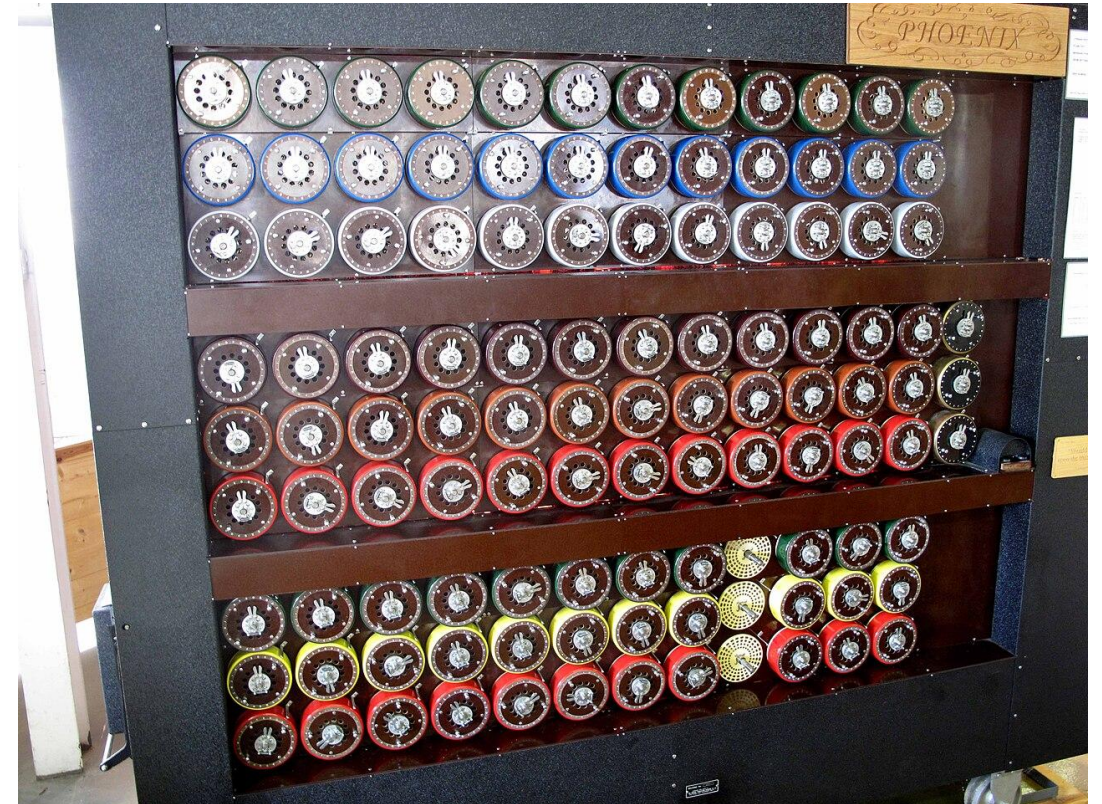
- **Scytale (Spartan cipher)**

- Wrapped parchment around a stick to read a message.

Mechanical Era (1900 – 1950)

With the arrival of machines, stronger ciphers were created.

- **Enigma Machine** (World War II)
 - German electro-mechanical cipher machine.
 - Very complex for its time.
 - Eventually cracked by Alan Turing.
- Introduced idea of key complexity and daily rotation



Early Computer Era (1950 – 1980)

Cryptography became a computer science discipline.

DES (Data Encryption Standard – 1977)

- Key size: 56-bit
- Block size: 64-bit
- Adopted by US government

Eventually broken by brute force (too small keyspace)

Modern Cryptography (1980 – 2015)

RSA (1977)

- Asymmetric encryption
- Uses large prime numbers
- Used in HTTPS, email

AES (2001 – present)

- Key sizes: 128, 192, 256-bit
- Very fast and secure
- Current global standard

SHA & Hashing family

- MD5 (broken)
- SHA-1 (broken)
- SHA-256 (safe, used in blockchain)

Triple DES (3DES)

- Used DES three times → stronger
- Slower

ECC (Elliptic Curve Cryptography)

- Smaller keys, stronger security
- Used in mobiles, IoT

- Strong mathematical encryption was introduced.
- This period gave us internet security.

Current Era – Post-Quantum Cryptography (2015 – Present)

- New algorithms created for quantum resistance.
- With quantum computers, RSA & ECC can be broken.
- So new ones include:
 - **Quantum-resistant algorithms**
 - CRYSTALS-Kyber (Encryption)
 - CRYSTALS-Dilithium (Signatures)
 - SPHINCS+
 - Falcon
- NIST is evaluating and standardizing them.
- These will power future internet security.



Salt

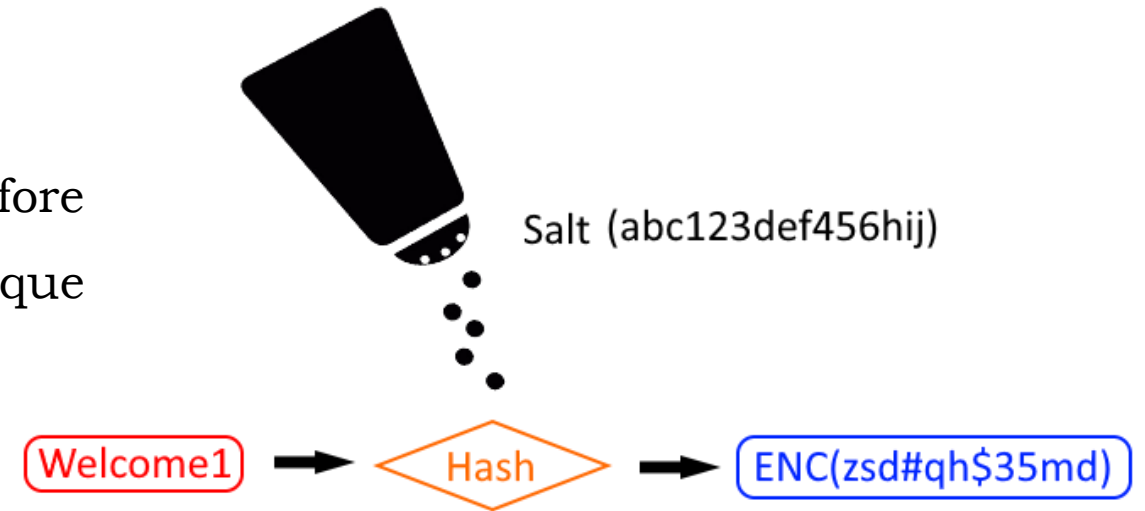
- A salt is a random value added to data before hashing to ensure that each hash output is unique — even if two users have the same password.

- **Purpose of a Salt**

- Prevents attackers from using precomputed hash tables (Rainbow Tables)
- Ensures same password $\neq$ same hash
- Adds uniqueness to each hash

- **Where Salt is used**

- Password hashing (bcrypt, PBKDF2, Argon2, scrypt)
- Storing credentials securely (/etc/shadow)



Example

- Password: **admin123**
- Salt: **X7@91#**
- Hash input becomes: **X7@91#admin123**



Nonce

- A nonce (**Number used once**) is a unique, one-time value used during encryption to prevent replay attacks and ensure unpredictability.

- **Purpose of a Nonce**

- Prevents replay attacks
- Ensures same message encrypted multiple times gives different ciphertexts
- Used in protocols and block ciphers

- **Where Nonce is used**

- AES-GCM, AES-CTR modes
- TLS handshake
- Digital signatures
- Blockchain
- OTP (One-Time Password)

Example

- Message: **HELLO**
- Key: **ABCD**
- Nonce: **845239**

Key points

- Must never repeat (uniqueness is critical)
- Can be public (not secret)
- Often based on:
 - Counters
 - Random numbers
 - Timestamps

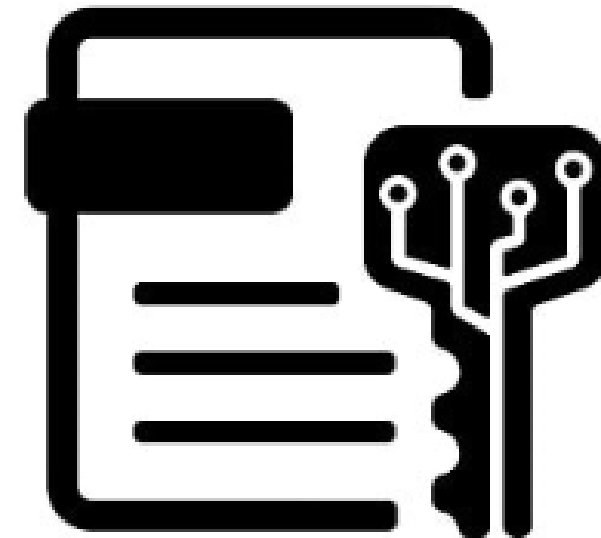
NONCE

A random or unique number used only once, vital for cryptographic security and replay protection.



Digital Certificates

- Digital Certificates are electronic documents used to prove the identity of a person, device, server, or organization on a network.
- They act like a digital ID card that helps establish secure communication over the internet.
- A Digital Certificate is a file issued by a trusted authority (CA) that binds a public key to the identity of an entity, ensuring:
 - **Authentication** – verifies who you are
 - **Encryption** – enables secure communication
 - **Integrity** – ensures data has not been tampered with
- Example:
 - Digital Certificate = PAN/Aadhaar + Public Key
 - Issued by trusted authority (CA)
 - Confirms identity
 - Used for secure transactions



What's inside a Digital Certificate?

A typical certificate (X.509 certificate) contains:

- Owner's Name (e.g., domain name: google.com)
- Owner's Public Key
- Issuer (Certificate Authority name)
- Validity period
- Serial number
- Digital signature of the CA
- Signature algorithm
- Key usage (what the certificate is allowed to do)



Who issues Digital Certificates?

Certificate Authority (CA)

- Examples include:

- DigiCert
- GlobalSign
- Let's Encrypt
- Sectigo
- Entrust



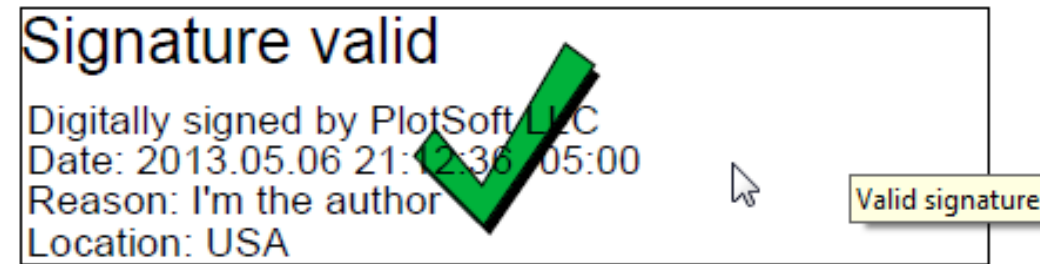
How to create a digital certificate?

- OpenSSL
- Makecert.exe
- PowerShell cmdlet (New-SelfSignedCertificate)
- Certification Authority (CA) MMC (in Windows Server)
- Security CLI Tool (for MacOS)
- Azure Key Vault
- AWS Certificate Manager
- Google Cloud Certificate Manager
- Microsoft AD CS service

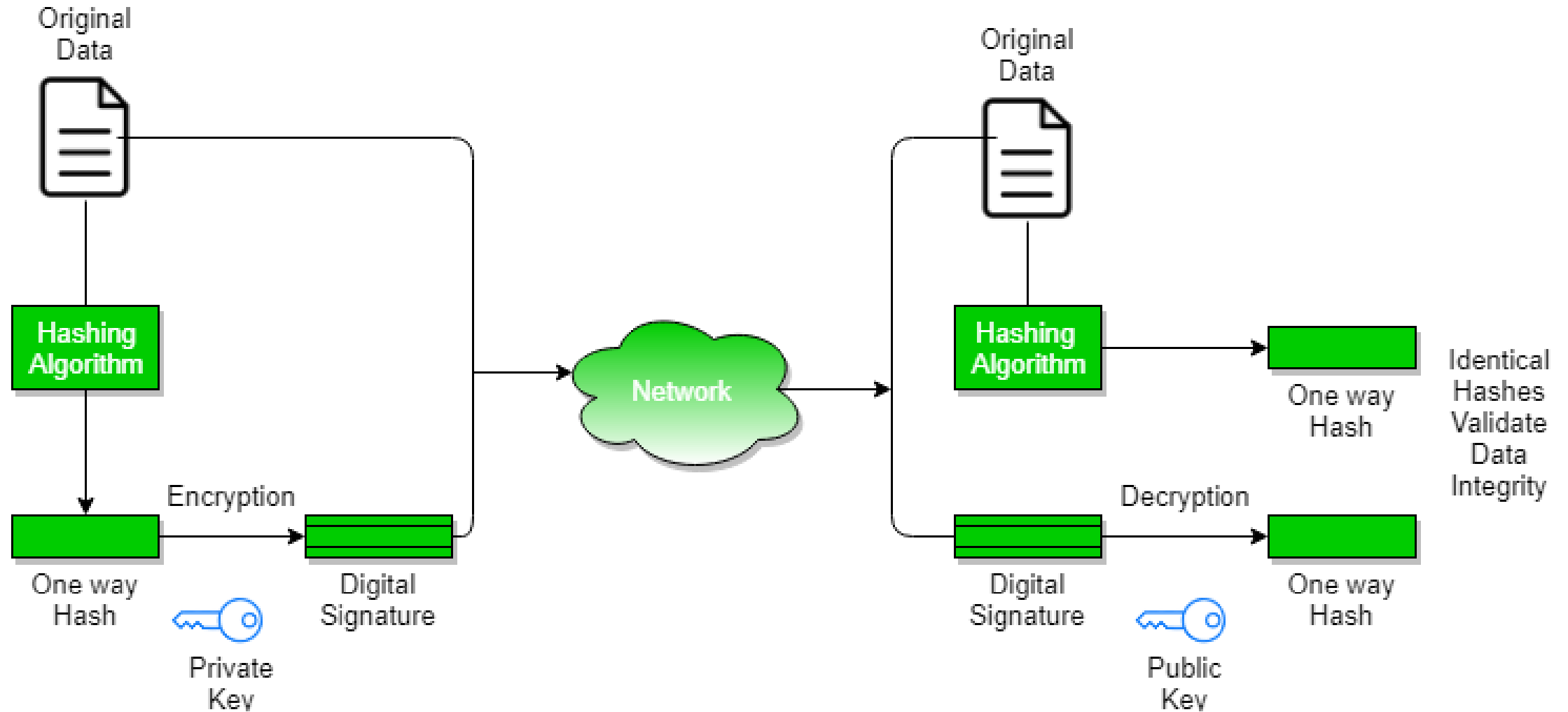


Digital Signatures

- A Digital Signature is a cryptographic mechanism used to verify the authenticity, integrity, and non-repudiation of a digital message, file, or document.
- A digital signature is the electronic equivalent of a handwritten signature, but far more secure. It proves who sent the message and ensures it wasn't changed.
- It uses asymmetric cryptography:
 - ✓ Private Key → Used to create the signature
 - ✓ Public Key → Used to verify the signature
- Analogy
 - ✓ *Traditional signature:*
 - You sign a paper → anyone can compare with reference signature.
 - ✓ *Digital signature:*
 - You sign a document with your private key → anyone can verify it using your public key.



Working of Digital Signature



What the Diagram Shows

- **Original Data / Document** — The file or message you want to sign.
- **Hash Function** → Hash (Message Digest) — The data is first hashed, producing a fixed-size summary (digest).
- **Signing with Private Key** — The digest is encrypted using the sender's private key to produce the digital signature.
- **Transmit Document + Signature** — Both the original data and the signature get sent to the recipient.



What the Diagram Shows

■ Verification at Recipient Side

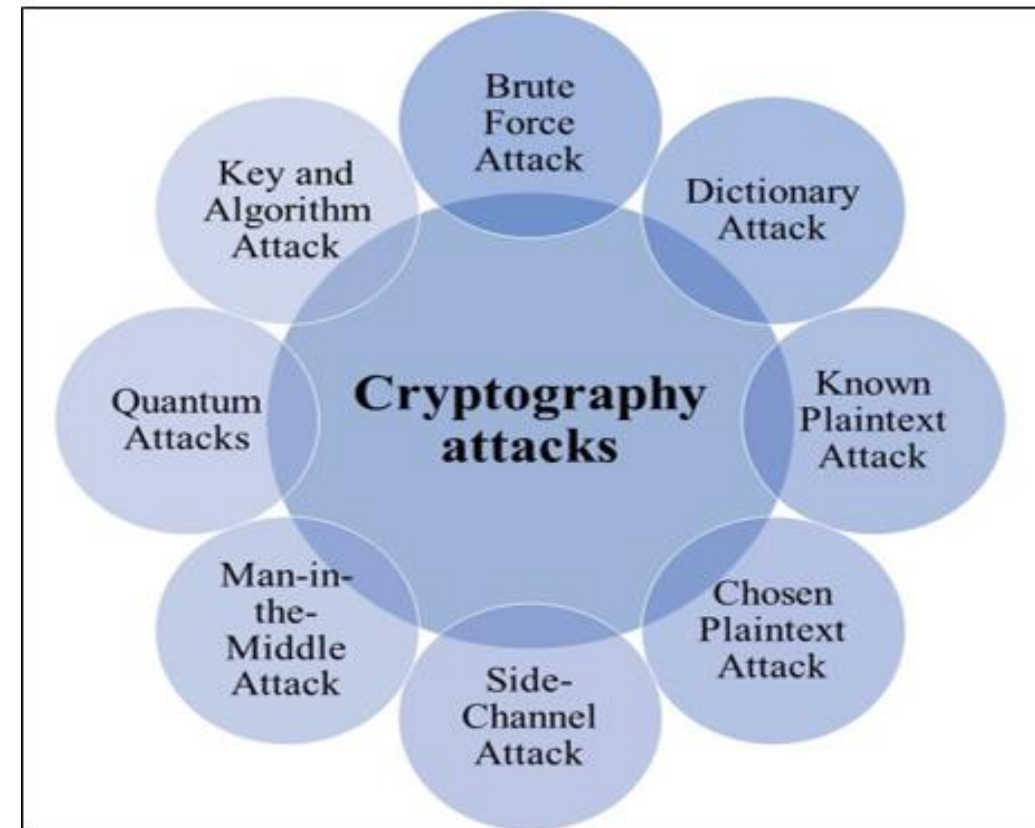
- Recipient hashes the received data to generate a new digest.
- Recipient decrypts the signature using sender's public key to retrieve the original digest.
- If both digests match → signature is valid (data intact, sender authenticated).
- If they don't match → data is altered or signature invalid.

This ensures **authentication, integrity and non-repudiation** — the core benefits of digital signatures.



Attacks on Crypto

- The attack is generally on algorithms, keys, protocols or implementations.
- List of attacks on cryptography are:
 - Brute-Force Attack
 - Dictionary Attack
 - Rainbow Table Attack
 - Known-Plaintext Attack (KPA)
 - Chosen-Plaintext Attack (CPA)
 - Chosen-Ciphertext Attack (CCA)
 - Side-Channel Attacks
 - Replay Attack
 - Man-in-the-Middle Attack (MITM)
 - Birthday Attack
 - Collision Attack
 - Weak Key Attack
 - Padding Oracle Attack
 - Frequency Analysis Attack
 - Quantum Attacks (Future Threat)



Attacks on Crypto – Summary

S.No	Attack Type	Targets	Examples
1	Brute Force	Keys	DES
2	Dictionary	Password Hashes	Hashcat
3	Rainbow Table	Unsalted Hashes	MD5
4	KPA/CPA/CCA	Encryption Algorithms	RSA, AES
5	Side-Channel	Hardware	Smartcards
6	Replay Attack	Authentication	Tokens
7	MITM	Network Comm	Wi-Fi
8	Birthday	Hashes	SHA-1
9	Collision	Integrity	MD5
10	Padding Oracle	Block Ciphers	AES-CBC
11	Frequency	Classical Ciphers	Caesar
12	Quantum	RSA/ECC	Shor's Algorithm



Attacks on Crypto

- **Brute-Force Attack:** Attacker systematically tries all possible keys or passwords until the correct one is found.
- **Dictionary Attack:** Attacker uses a predefined list of common passwords or words to guess cryptographic secrets.
- **Rainbow Table Attack:** Attacker uses precomputed hash tables to reverse password hashes without salting.
- **Known-Plaintext Attack (KPA):** Attacker analyzes known plaintext–ciphertext pairs to deduce the encryption key.
- **Chosen-Plaintext Attack (CPA):** Attacker encrypts chosen plaintexts to study ciphertext patterns and break encryption.
- **Chosen-Ciphertext Attack (CCA):** Attacker decrypts chosen ciphertexts to extract secret keys or plaintext information.
- **Side-Channel Attacks:** Attacker exploits physical leakages such as timing, power consumption, or EM emissions.
- **Replay Attack:** Attacker reuses captured valid authentication data to gain unauthorized access.
- **Man-in-the-Middle Attack (MITM):** Attacker intercepts and alters communication between two parties without detection.

Attacks on Crypto

- **Birthday Attack:** Attacker exploits hash collision probability to find two inputs with the same hash value.
- **Collision Attack:** Attacker deliberately finds different inputs producing identical hash outputs.
- **Weak Key Attack:** Attacker exploits poor or predictable key generation to compromise encryption.
- **Padding Oracle Attack:** Attacker uses padding error responses to decrypt encrypted data without the key.
- **Frequency Analysis Attack:** Attacker analyzes character frequency in ciphertext to break substitution ciphers.
- **Quantum Attacks (Future Threat):** Quantum computers use algorithms like Shor's to break RSA and ECC cryptography.





That's all Folks!